Lab 9: Threat-Model and Secure a Finance Agent

TGS-2026065050 · Tertiary Infotech Academy Pte Ltd

Lab 9: Threat-Model and Secure a Finance Agent

Course: Generative AI for Finance and Fintech (TGS-2026065050)

Mapping: K3 · A4

Suggested time: 120 minutes

Objective: Apply identity, DLP, prompt-injection, data, tool and monitoring controls to a finance agent.

Scenario

The finance query agent is proposed for wider deployment with SharePoint knowledge and workflow connectors.

Files

- `northstar-agent-security-starter.xlsx` - learner working file
- `northstar-agent-security-solution.xlsx` - completed formulas, controls and charts for review
- `evidence-checklist.md` - submission and verification checklist
- `adversarial-prompts.json` - synthetic security tests

Before you begin

- Use only the supplied synthetic data.
- Do not enter live customer, payroll, account, credential or confidential data.
- If the required Microsoft feature is not enabled in your tenant, complete the workbook-based simulation and record the limitation.
- Keep facts, assumptions, AI suggestions and reviewer decisions visibly separate.

Detailed procedure

Step 1: Inventory users, data, knowledge sources, tools and external dependencies.

Record the evidence for Step 1 in the checklist before continuing.

Step 2: Map prompt injection, leakage, poisoning, tool abuse, identity and third-party threats.

Record the evidence for Step 2 in the checklist before continuing.

Step 3: Assign preventive, detective and responsive controls using the control matrix.

Record the evidence for Step 3 in the checklist before continuing.

Step 4: Classify connectors into business, non-business and blocked groups.

Record the evidence for Step 4 in the checklist before continuing.

Step 5: Run the supplied adversarial prompts using synthetic data only.

Record the evidence for Step 5 in the checklist before continuing.

Step 6: Issue a publish, remediate or reject recommendation with residual risk and owner.

Record the evidence for Step 6 in the checklist before continuing.

Prompt quality pattern

> Role: You are assisting a finance professional. Task: analyse only the named workbook table. Data boundary: do not use external or unstated facts. Controls: reconcile totals, identify missing evidence, and label assumptions. Output: return a concise table of finding, evidence, confidence, reviewer action and source cell or table.

Acceptance criteria

- Every high risk has a preventive and detective control, test evidence, residual rating and accountable owner; no live credentials or customer data are used.
- All generated claims have been checked against the workbook or approved knowledge.
- No live credentials, personal data or confidential business data appear in the evidence.
- A human reviewer and approval status are recorded.

Deliverable

A threat model, control matrix, adversarial test log and publish recommendation.

Reflection

1. What did the AI accelerate?
2. What still required finance judgement?
3. Which control prevented the most serious failure?
4. What evidence is needed before this design can scale?

© 2026 Tertiary Infotech Academy Pte Ltd · UEN 201200696W